

River Publishers Series in Security and Digital Forensics

GDPR and Cyber Security for Business Information Systems

ANTONI GOBEO
CONNOR FOWLER
WILLIAM J. BUCHANAN



River Publishers

GDPR and Cyber Security for Business Information Systems

RIVER PUBLISHERS SERIES IN SECURITY AND DIGITAL FORENSICS

Series Editors:

WILLIAM J. BUCHANAN

Edinburgh Napier University, UK

ANAND R. PRASAD

NEC, Japan

Indexing: all books published in this series are submitted to the Web of Science Book Citation Index (BkCI), to CrossRef and to Google Scholar.

The “River Publishers Series in Security and Digital Forensics” is a series of comprehensive academic and professional books which focus on the theory and applications of Cyber Security, including Data Security, Mobile and Network Security, Cryptography and Digital Forensics. Topics in Prevention and Threat Management are also included in the scope of the book series, as are general business Standards in this domain.

Books published in the series include research monographs, edited volumes, handbooks and textbooks. The books provide professionals, researchers, educators, and advanced students in the field with an invaluable insight into the latest research and developments.

Topics covered in the series include, but are by no means restricted to the following:

- Cyber Security
- Digital Forensics
- Cryptography
- Blockchain
- IoT Security
- Network Security
- Mobile Security
- Data and App Security
- Threat Management
- Standardization
- Privacy
- Software Security
- Hardware Security

For a list of other books in this series, visit www.riverpublishers.com

GDPR and Cyber Security for Business Information Systems

Antoni Gobeo

Edinburgh Napier University, UK

Connor Fowler

Edinburgh Napier University, UK

William J. Buchanan

Edinburgh Napier University, UK



River Publishers



Routledge
Taylor & Francis Group

LONDON AND NEW YORK

Published 2018 by River Publishers
River Publishers
Alsbjergvej 10, 9260 Gistrup, Denmark
www.riverpublishers.com

Distributed exclusively by Routledge
4 Park Square, Milton Park, Abingdon, Oxon OX14 4RN
605 Third Avenue, New York, NY 10017, USA

GDPR and Cyber Security for Business Information Systems/by Antoni Gobeo, Connor Fowler, William J. Buchanan.

© 2018 River Publishers. All rights reserved. No part of this publication may be reproduced, stored in a retrieval systems, or transmitted in any form or by any means, mechanical, photocopying, recording or otherwise, without prior written permission of the publishers.

Routledge is an imprint of the Taylor & Francis Group, an informa business

ISBN 978-87-93609-13-6 (print)

While every effort is made to provide dependable information, the publisher, authors, and editors cannot be held responsible for any errors or omissions.

DOI: 10.1201/9781003338253

Contents

Preface	xi
Acknowledgements	xiii
List of Figures	xv
List of Abbreviations	xvii

PART ONE: INTRODUCTION

1	The GDPR Fundamentals	3
	A Brief History of Data Collection and Data Protection.....	4
	The GDPR	5
	To Whom Does It Apply?	6
	Who Is Exempt?.....	6
	Personal Data: Why it's Worth Protecting	7
	The Privacy Argument	8
	The Economic Argument	11
	Consequences to Individuals of Data Misuse	12
	The Heart of the GDPR; The Six Principles.....	13
	The Six Lawful Bases	14
	The Rights of Natural Persons in the GDPR	22
	The Three Exceptions	28
	Chapter Review	30
	References	30
	Appendix	33
2	Organisations, Institutions, and Roles	37
	Introduction	38
	Quis Custodiet Ipsos Custodes?.....	38
	European Union	38

Duties of the EDPB	40
Supervisory Authorities	41
The ICO in Action	44
Organisations Under the GDPR	44
Public Authorities	44
Types of Public Authorities.....	45
NGO's and Charities.....	45
NGO's and Charities as Data Controllers	46
Institutions and Agencies.....	47
Court of Justice of the European Union	48
European Union Agency for Network and Information Security: ENISA	49
The United Kingdom	50
Government Communications Headquarters	50
The National Cyber Security Centre.....	53
The GCHQ Bude: GCHQ Composite Signals Organisation Morwenstow	53
Investigatory Powers Commissioner's Office.....	54
Investigatory Powers Tribunal	56
Chapter Review	58
References	58
Appendix	60
 3 Information Systems Management and the GDPR	 69
Introduction	70
Information Systems in Organisations	71
Processes and Essential Systems	72
Types of Information Systems	73
Information Management	75
What is IM	75
Stakeholders	75
Data Management through the Ages.....	76
Functions of Information Management	78
Information Systems Theory	79
Data Flow Mapping	82
Data Flow Mapping Techniques	84
Data Controller and Data Processor	86
Data Controller	87
Data Processor	87

	Distinguishing the Difference Between the Data Controller and the Data Processor.....	88
	Chapter Review	91
	References	91
4	Cyber Security and the GDPR	93
	Introduction	94
	Cyber Security as a Function of Compliance	95
	Privacy	95
	Protection.....	96
	Process	98
	Cyber Attacks	99
	Malware	100
	Social Engineering.....	103
	Phishing	108
	Countermeasures	110
	Encryption.....	110
	Chapter Review	114
	References	114

PART TWO: PREPARATORY STEPS

5	Data Protection by Design and Default	119
	Introduction	120
	Data Protection is a Program; not a Project.....	120
	What is Privacy?	121
	Privacy and Protection by Design and Default	122
	The Security Principle: Appropriate Technical and Organisational Measures	125
	Organisational: A Corporate Culture of Data Protection.....	126
	Staff Awareness of Security	127
	Organisational Responsibility for Security.....	129
	Technical Measures.....	129
	Physical Security	129
	Hardware Security	131
	Computer Security: Design.....	132
	Computer Security: Measures.....	133

Open Web Application Security Project (OWASP)	135
Assessing Information Assets: Value and Risk.....	136
Information Classification and Labelling	137
Special Category Data: Sensitive and Very Sensitive	
Personal Data	138
Criminal Offence Data.....	138
Labelling of Data	138
Chapter Review	140
References	140
Appendix	143
 6 Protection Policies and Privacy Notices	 145
Introduction	146
Policy Framework: COBIT 5.....	147
COBIT 5: Principles, Policies and Frameworks in Depth	151
The Data Protection Policy.....	154
Policy Document Structure.....	155
Data Protection Privacy Notice.....	157
Types of Privacy Notices	159
Chapter Review	160
References	161
 7 DPO, DPIA, and DSAR	 163
Introduction	164
Data Protection Officer.....	164
Appointing a DPO	165
What Makes a good DPO?.....	167
Tasks of the DPO	168
Data Protection Impact Assessment	170
Legal Requirements	171
Defining Article 35	173
Prior Consultation.....	175
Conducting a DPIA	176
Data Subject Access Request.....	178
How to access the data.....	179
The Organisations Role	180
Chapter Review	181
References	182
Appendix	183

PART THREE: IMPLEMENTATION

8	International Standards; ISO's	189
	The ISO.....	190
	4 Key Principles	190
	5 Year Review Process	191
	ISO as a Function of Compliance	191
	ISO 31000: Risk Management	191
	The Eight Principles	192
	Five Component Framework	193
	Six Stage Process	194
	ISO 27005: A Brief Visit.....	196
	ISO 8601: Representation of Dates and Times.....	196
	ISO 27000 Family – Information Security Management Systems... 198	
	ISMS: Information Security Management Systems	198
	ISO 27018: Code of Practice for Protection of Personally Identifiable Information (PII) in Public Clouds Acting as PII Processors	200
	ISO 27032: Guidelines for Cybersecurity	201
	ISO 9001 – Quality Management System	202
	Plan-Do-Check-Act Cycle	204
	Chapter Review	206
	References	206
9	Security Incident Management	209
	Introduction	210
	The GDPR Articles	210
	Computer Security Incident Response Team (CSIRT).....	211
	Incidence Response Plan (IRP)	213
	Incident Response Cycle.....	213
	Notification for a Personal Data Breach	224
	Data Breach Severity	225
	Breach Severity Rating and Risk	227
	ENISA Methodology	229
	Chapter Review	231
	References	232
	Appendix	233

10 Valuing Security	235
Valuing Security: Making the Business Case	236
Budgeting for IT and C-Suite	237
Budgeting.....	239
Mapping Out the Budget	242
Money Talks	244
Calculating the Annualised Loss Expectancy	244
Calculating the Return on Investment.....	245
Effective Communication	247
Email.....	249
Preparing a Presentation	251
Chapter Review	256
References	257
 Index	 259
 About the Authors	 263

Preface

Data misuse in the modern age has reached critical levels, without the public at large knowing the real extent the data they produce is being abused. The recent trends of data breaches from Equifax (2017) to companies such as Facebook and Google covertly selling personal data to analytics companies without the users consent, has prompted major shifts in the regulatory environment. The General Data Protection Regulation (GDPR) is the latest in data protection law to come out of the European Union. The regulation has created an increased awareness of the wild west nature of the data world, and how hidden and known players, malicious or otherwise, are attempting to control our worlds. This book was written, among other reasons, to allow the new generations of students to enter the business world with a greater sense of confidence in the face of ever evolving challenges in an increasingly connected world. The readers of this book should come away with a better understanding of the importance the GDPR has on shaping the digital and business world, and practical skills with which to apply that understanding.

The book is broken into three parts the introductory chapters (1–4), the preparation (5–7), and finally the implementation chapters (8–10). It is important that the reader reads part one first in order to gain a foundation of the basic subjects covered in the book (ideally cover to cover would be best). After having read part one there is no particular order in which the chapters of each part (2 & 3) should be read, as the principles covered in part one should give the reader enough knowledge to understand the topics covered in the respective chapters. It is not necessary to have read the GDPR from start to finish to understand the material covered in this book, the text was written in a way to simplify complex legalese into something that can be easily understood by students in their first year of University. The Articles most relevant to business information systems are quoted in the text so there is no need to have a copy of the regulation next to you as you read, but for the extra hard working, the full text of the regulation can be found online, for free, if you wish to read the Articles that are not mentioned in full detail. The book

should also be able to be read in a way where one can easily pick it up to see, for example, how a business should conduct a DPIA? The answer to which can be learned if you read on.

For many people, using the internet is a common and daily occurrence, but they rarely see or understand the consequences of an untrustworthy internet, one that we have allowed to continue. It is our duty as authors to disseminate information of progressive moves, such as this regulation, towards building a society where the individual's digital and physical rights are held above the commercial interests of large corporations and governments. Together we hope to achieve that goal, thank you for reading.

Acknowledgements

It is a great gift to have the opportunity of working with such an inspiring educator as Bill Buchanan, without whom this book would not have been written; thank you Bill!

Thank you to Edinburgh Napier University, whose commitment to helping students achieve their highest potential has been on clear and constant display. A special thanks to the lecturers in the Business School, Faculty of Law, and to Mr Ken Dale-Risk; who patiently listened to many questions over the years.

There are key moments in life where someone else encourages us to believe in ourselves. My college lecturer, Ms Alison Bruce, urged me to have confidence in my abilities and helped me stay the course. Thank you, Alison!

To Anna and Dave: Thank you for your patient, stable, and wise support.

Most importantly; Tiberius and Freya, who endured many months of data protection “chats” and ready meals: you guys are Awesome! Thank you!

– Antoni

It has been a great experience diving into the world of data protection, but none of this could have been possible without the people in my life.

I would like to start by thanking the most important people in my life my love Antoni, who joined me on this journey, and the two brightest stars in my life Tibs and Freya.

A special thanks to Bill and Napier University who presented me with this great opportunity and John, the best cheerleader you could ask for, we should do dinner!

And finally, *per la mia nonna che ha cucinato sempre con amore, Dio ti benedica.*

– Connor



Taylor & Francis

Taylor & Francis Group

<http://taylorandfrancis.com>

List of Figures

Figure 2.1	The Hierarchy of the European Data Protection Board	40
Figure 3.1	Extended Information System.....	73
Figure 3.2	Hierarchical system for information management.....	74
Figure 3.3	Data Mapping Techniques.....	84
Figure 3.4	Simple data flow map.....	86
Figure 3.5	Data Controller v Data Processor.....	89
Figure 4.1	<i>Wanacry</i> ransomware attack	103
Figure 4.2	Example of a phishing email.....	109
Figure 6.1	5 principles of COBIT 5.....	149
Figure 6.2	Enablers of COBIT 5	151
Figure 7.1	DPO Appointment Criteria Flow Chart.....	167
Figure 9.1	CSIRT Hierarchy.....	212
Figure 9.2	Incident Response Plan NIST	214
Figure 9.3	The OODA Loop.....	219
Figure 10.1	IT budget assessment	238
Figure 10.2	Run, grow, transform.....	240
Figure 10.3	Metcalf's law graph.....	246
Figure 10.4	Prospect Theory	249



Taylor & Francis

Taylor & Francis Group

<http://taylorandfrancis.com>

List of Abbreviations

AWS3	Amazon Web Simple Storage Service
BCM	Business Continuity Management
BIS	Business Information Systems
CEU	Council of the European Union
CIA	Confidentiality, Integrity, Availability
CIO	Chief Information Officer
CISO	Chief Information Security Officer
CJEU	Court of Justice of the European Union
CSIRT	Computer Security Incidence Response Team
CSO	Composite Signals Organisation
C-Suite	“Chief” managers in an organisation
DC	Data Controller
DCMS	Department for Digital, Culture, Media, and Sport
DP	Data Processor
DP	Data Protection
DPIA	Data Protection Impact Assessment
DPO	Data Protection Officer
DSAR	Data Subject Access Request
EC	European Commission
ECHR	European Court of Human Rights
ECJ	European Court of Justice
EDPB	European Data Protection Board
EDPS	European Data Protection Supervisor
ENISA	European Union Network and Information Security Agency
EP	European Parliament
FTC	Federal Trade Commission (USA)
GCHQ	Government Communications Headquarters
GDPR	General Data Protection Regulation
HMRC	Her Majesty’s Revenue and Customs (UK)
IM	Information Management
InfoSec	Information Security
IOCCO	Interception of Communications Commissioner’s Office

IoF	Institute of Fundraising
IoT	Internet of Things
IP address	internet protocol address
IPCO	Investigatory Powers Commissioner's Office
IPT	Investigatory Powers Tribunal
IRP	Incidence Response Plan
IS	Information Systems
ISACA	Information Systems Audit and Control Association
ISMS	Information Security Management Systems
ISO	International Standards Organisation
IT	Information Technology
JPCERT	Japan Computer Emergency Response Team Coordination Centre
MBR	Master Boot Record
MI5	Security Service (UK)
MI6	Secret Intelligence Service (UK)
MIS	Management Information Systems
NCA	National Crime Agency
NCSC	National Cyber Security Centre
NDA	Non-disclosure Agreement
NFP	Not-for-Profit Organisation
NGFW	Next-Generation Firewall
NGO	Non-governmental Organisation
NIS	Network and Information Security
NIST	National Institute of Standards and Technology (USA)
NSA	National Security Agency (USA)
OECD	Organisation for Economic Development
OODA Loop	Observe, Orient, Decide, Act Loop
OSC	Office of Surveillance Commissioners
PA	Public Authority
PaP	Policies and Procedures
PbD	Privacy by Design
PDCA	Plan, Do, Check, Act cycle
PII	Personally Identifiable Information
PLP	Principle of Least Privilege
QM	Quality Management
RM	Risk Management
SA	Supervisory Authority
SIA	Secret Intelligence Agencies
SIEM	Security Incident Events Management
SIGINT	Signals Intelligence

1

Part One: Introduction

Chapters Covered

- 1) GDPR Fundamentals
- 2) Organisations, Institutions, and Supervisory Authorities
- 3) Business Information Systems
- 4) The GDPR and Cyber Security

Section Overview

This part of the book is intended to give the readers introductory knowledge of the subjects covered in this book. The topics covered will start with an analysis into the fundamental of the GDPR (the rights and principles), an overview of the supervisory authorities of the GDPR and the institutions and organisations affected by the legislation, what is business information systems and how they relate, and finally cyber security and how it can be utilised in the context of the GDPR. It will be helpful to think about this section through the lens of both and organisation and as an individual, allowing for a wholesome perspective on what the spirit of the legislation means. Below are some examples of things to consider.

The Organisations and You



Chapter 1: The GDPR Fundamentals

At a Glance:

- ❖ History of data protection and collection
- ❖ Personal data and its worth
- ❖ Rights of the natural persons under the GDPR
- ❖ Six Principles of the GDPR

Case Study: Cambridge Analytica

Learning Outcomes: *Students should be able to...*

- ❖ Understand the six principles underpinning the GDPR and their relevance in legislative compliance.
- ❖ Describe the rights of the data subjects and when and how they apply.
- ❖ Explain the value and uses of personal data and the potential consequences to the individual of its misuse.

Key Terms

- 1) Natural Persons
- 2) Personal Data
- 3) Data Subject
- 4) Data Controller
- 5) Data Processor
- 6) Rights and Principles
- 7) Data Minimisation
- 8) Lawful Basis

A Brief History of Data Collection and Data Protection

Governments and Institutions have been collecting personal data on their citizens since the beginning of recorded history. During the times of the Roman Empire taxation records were kept including the names, addresses, and incomes of Roman citizens. These records were consolidated and used for various purposes, depending on the desires of the emperor at the time. One thousand years later the Domesday Book of 1086 AD was instigated by William the Conqueror, in an attempt to clarify the rights to property and assets after the Norman conquest of England and Wales. It was the greatest survey of a nation's people and assets ever undertaken in Europe until that time, and the personal data collected was used for taxation purposes.

The interception of personal correspondence in “the national interest” has a long and royal pedigree. In 1516, during the reign of Henry VIII of England, the first “Master of the Posts” was appointed. This early form of postal service delivered royal mail; quite literally the mail for the king and his court. The convenience offered by this new service was offset by the knowledge that the letters would very likely be read by agents of the king. Later, in 1660 the General Post Office was established under the Reformation king Charles II, simultaneously establishing the “Secret Office” within the GPO, whose sole role was to spy on foreign correspondence entering and leaving England.

In modern times there has been an evolving recognition that individuals need to be protected from the misuse and abuse of their personal data, especially by governments and powerful organisations. In 1950, the European Convention of Human Rights enshrined the Right to Respect for Private and Family life (Article 8). This right includes the home and private correspondence as areas for protection within an individual's family and private life.

Building on this right the Council of Europe Convention 108 for the *Protection of Individuals with regard to Automatic Processing of Personal Data* 1981 was introduced. This was the first internationally adopted law specific to data protection, with the clear aim of protecting the privacy of personal data. In 1995, the European Union Directive 95/46/EC on the protection of individuals regarding the processing of personal data and on the free movement of such data, was enacted. Known as the Data Protection Directive, it was the central piece of legislation on the protection of personal data in the EU and stipulated the requirement for explicit consent to the collection of personal data from the individual concerned.

The *Charter of Fundamental Rights of the European Union* included the protection of personal data as a fundamental right¹ and this is mirrored in the *Treaty on the Functioning of the European Union*². Despite the clear intention to protect personal data, by 2012 it had become clear that the fragmentary nature of data protection legislation needed reform and the Commission of the EU published its suggestions. After three years of negotiations, the European Parliament and the Committee of the EU (made up of ambassadors from the 28-member states) finally agreed to the new regulation, and it became law in 2016.

The GDPR

The General Data Protection Regulation (GDPR) is the latest legislation on data protection arising from the European Union and came into effect in May 2018. It is designed to update the existing legislation to make it relevant to current technological trends and to bring conformity of compliance across the EU. There are three main objectives; to reinforce the protection of personal data for individuals, to assist the free flow of data within the single market (EU), and to reduce administrative burden. The situation within the EU Member states, prior to the introduction of the GDPR, was one of many fragmented and divergent sets of data protection laws relevant to each country. The harmonisation of data protection legislation across the EU allows for greater ease in the flow of data across the Union. It also allows for a specific authority to be nominated in each Member State; which creates a single point of reference for individuals and organisations. Member States may include specific additions to their local data protection laws, to provide further rights to their citizens.

Whilst similar to previous Data Protection legislation, the GDPR enhances the rights of Data Subjects and introduces enforceable new rights. Children are given a specific category of protection which acknowledges their vulnerability to the risks of sharing personal data; especially online. Children are also significantly less likely to know their rights regarding the processing of personal data.

In effect, the GDPR develops in further detail many of the already existing principles of data protection whilst encouraging a risk-based

¹ Article 8(1)

² Article 16

approach in assessing the level of protection required to meet the obligations for data controllers and processors to document their accountability and compliance.

This legislation is designed to deal with the ongoing challenges arising from the ever-changing online world and the massive increase in personal data volume and data flows globally. In response to increasing numbers of breaches of personal data, and to the lackadaisical attitude of many businesses, the new legislation has introduced significantly increased obligations and more onerous sanctions. The oft quoted ability to fine companies 4% of global turnover is only one example, and arguably not the most detrimental to the business.

To keep the regulation relevant in the face of unknown future developments, it is worded in technologically neutral terms. This means that the GDPR can be interpreted very broadly when decisions about what is within its scope, need to be made. Thus, it is extremely important to understand the objectives and principles that the GDPR is based on, as it will facilitate every step in the decision-making process.

To Whom Does It Apply?

The GDPR is primarily aimed at protecting data subjects. Data subjects are individuals who are identified or identifiable natural persons (living, breathing human beings) who are:

- ❖ Within the EU
- ❖ Whose behaviour takes place within the EU and is being monitored
- ❖ Natural persons whose data is being processed by an establishment within the EU.

The obligation to provide this protection also applies to organisations who are not based in the EU but who offer goods and services, with or without fee, to data subjects within the EU

Who Is Exempt?

There are two broad areas in which the GDPR does not apply; in the home, and for the purposes of law enforcement.

Household exemption

The processing of personal data by a natural person, for domestic or personal purposes, is not within the scope of the GDPR. The important aspects

here are that the processing is by a natural person (an individual) and is in no way connected to professional or commercial activities. Therefore, doing your household budget or planning a family holiday is exempt from the requirements of the GDPR. However, work activities involving personal data that are carried out at home *are included* under the GDPR, for example an accountant working from home using client's personal data must demonstrate compliance to the regulation. This highlights the need to keep work and private/social activities separated; ideally on separate devices.

Law enforcement exemption

Under specific circumstances the competent public authorities are exempt from the requirements within the GDPR. This applies especially to those bodies engaged in the policing of, and sentencing for, criminal activities. Typically, this includes the security services, the police, and the judicial system. Other public authorities, such as the health services or taxation department for example, may be called upon to aid law enforcement. This exemption applies under the following specific circumstances:

-
- ❖ ***Criminal offences:*** *In the prevention, detection, investigation, and prosecution of criminal offenses.*
 - ❖ ***Criminal penalties:*** *In the processing of personal data required for the application of criminal penalties.*
 - ❖ ***Threats to public security:*** *To safeguard the public against threats to security, and data processing for the prevention of such threats.*
-

Personal Data: Why it's Worth Protecting

Personal data under the GDPR is regarded as any personal information relating to a natural person; whether private, professional, or part of public life, it is considered as personal data. This data includes anything that could be used to personally identify an individual, either directly or indirectly, even

where that data is considered to be generalised data. Some of the categories are: name, age, identification number, location, physical, mental, genetic, biometric, email, economic, social, historic, and more.

There is no comprehensive list of categories given within the GDPR; this is to allow any future developments in data gathering to be included within the scope of the regulation. This broad range of data sources becomes especially relevant where profiling of data is used. As you might imagine, personal data covering all these categories can provide comprehensive insight into a given individual. In some cases, this insight provides intimate knowledge about an individual; information that they, themselves, may not be aware of. This level of detailed information is commercially valuable, and this has given rise to a culture of data misuse and abuse within industries that commodify it.

The Privacy Argument

There is an overused refrain, which is often heard when the topic of data protection is broached: “I have nothing to hide, there’s nothing interesting about me.”, or conversely; “If you have nothing to hide, then you have nothing to fear.” This implies that only “bad” people; criminals, terrorists, or other undesirables such as political dissidents, have something to fear from the analysis and the exposure of their private information. It also implies that the *only* people who can justify the desire for privacy are those same “bad” people. Another issue is that the notion of what constitutes “bad” behaviour is very narrowly defined by the public, but more broadly defined by governments and corporations. The public, in general, associates “bad” behaviour as that which damages an individual or society at large; behaviour that breaks fundamental laws, especially relating to the safety and security of the person and their property.

Institutions and corporations tend to see any behaviour that instigates unwanted change which affects them, as “bad”. This is much broader in scope and may include; external criticism, competition, or challenges to their mode of operation for example, in 2018, the banning of cryptocurrency related discussion and advertising, on many social media sites such as YouTube and Facebook illustrate this, even though many governments

around the world were researching the use or launch of a national cryptocurrency.

Similarly, this rhetoric gives rise to “self-surveillance”. If I have nothing to hide, then my activities, especially online, must reflect my innocence, but do they? If I know that government agencies, social media sites, search engines, phone companies, and supermarkets etc. collect my data to use in ways I have little control over; I may change the way I live my life. When we know we are being watched, or think we are, it changes our behaviour. We become more compliant and conformist, rather than taking independent action based on our own agency. We act based on the perceived expectations of us, often based on societal norms and the desire to avoid shame and judgement.

After the revelations by Edward Snowden in 2013, which exposed the existence of the NSA/PRISM program and the extent of the mass surveillance of the public, researchers conducted a study into the rise of self-surveillance. They found that even in the absence of any government prosecution or punishment for individuals accessing certain “sensitive” information; in this case Wikipedia pages relating to terrorism, there was a steady and prolonged decline in the number of people searching for information on these subjects. The researchers concluded that the primary reason for the decline was the knowledge of the existence of mass surveillance by government agencies.

Ultimately, privacy is sacrificed by the individual in exchange for not being labelled as “bad”. The dangers inherent in surveillance, through the collection and use of personal data, is mitigated only when the individual behaves in an unthreatening way. This is construed as complying with the status quo, or at the very least to keep dissent hidden and unspoken. This applies equally in politics as it does in commerce, and in the social sphere.

The Panopticon

The 18th century philosopher, Jeremy Bentham, developed the first modern system of mass surveillance and control; the Panopticon. A building designed to allow covert observation of all inmates held within it. The building was circular in design, with a central surveillance tower. The central tower allowed the guards to watch many inmates at once, but the most important aspect of the design was that the inmates could not see if, or when, they were being watched. Bentham realised that the outcome of this assumed surveillance was an increase in self-imposed conformist and compliant behaviour by the inmates. In 1843, he wrote that the panopticon was a new and unequalled method to gain control over another's mind. By the 20th century it was realised that this self-surveillance was the single greatest tool available for the mass control of human behaviour. In 1975, French philosopher Michel Foucault discussed self-surveillance as a product of the "Disciplinary State", which strives to create a prison of the mind not of the body. He argued that self-surveillance is much more effective than punishment, enforced loyalty, or imprisonment, in the creation of a subjected citizenry.

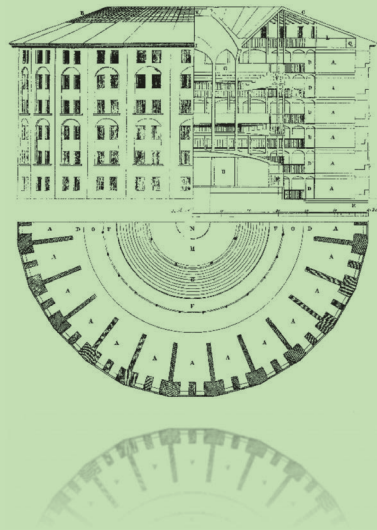


Image taken from: The Works of Jeremy Bentham Vol IV 172–3